



Kanon

3RD-WEB-HACK • TECHZAP CLUB • ETHEREUM SEPOLIA

The company decides. The agent operates.

Human-approved, Privy-enforced wallet authority for financial AI agents, with a company-controlled ENSv2 identity. A software update cannot quietly widen what an agent may do.

Financial agents need wallet authority. Today that authority is either too broad or too manual.

UNBOUNDED KEYS

Hot wallets in a backend

The agent can do far more than its task. App-level checks fail to a bug or a prompt injection.

SILENT ESCALATION

Updates inherit access

Version 2 asks for more spending power and keeps the old wallet access. Nothing forces a review.

NO PUBLIC RECORD

Who approved what?

Nobody outside can check which release a company approved or whether that authority was revoked.

Signing every transaction by hand is safe, and it defeats the point of automation.

Humans approve authority boundaries. Agents operate inside them.

KANON

The lifecycle

Declared capability, company terms, deterministic `permissionHash`, exact human approval, permission diff on every release, revocation.

PRIVY

Financial enforcement

Company-owned wallet. The agent gets a dedicated delegated signer with a signer-specific policy. Privy rejects anything outside it.

ENSv2

Company-controlled identity

Agent name under the company namespace with protected records: agent ID, approved release, permission hash, status.

Privy first, ENS second: the public record never claims authority the wallet does not enforce.

Twelve steps a judge can run in the browser

01

Register release

package + manifest hash

02

Review request

declared, not granted

03

Define authority

recipient, per-action, rolling

04

Human approves

exact permissionHash

05

Privy activates

policy + delegated signer

06

ENS records

release, hash, status

07

Allowed action

real Sepolia tx

08

Forbidden action

rejected by Privy policy

09

Broader release

diff = EXPANDED, blocked

10

Fresh approval

generation 0 → 1

11

Revoke

signer removed, ENS revoked

12

Post-revoke

execution fails

Authority is bound to a release, diffed on every update, and enforced by the wallet.

IDEA	WHAT IT MEANS
Release-bound approval	The decision binds release ID, package hash, manifest hash and <code>permissionHash</code> . A changed authority cannot reuse it.
Fail-closed permission diff	Every release is <code>NO_CHANGE</code> , <code>NARROWER</code> , <code>EXPANDED</code> , <code>SUBSTITUTED</code> or <code>UNKNOWN</code> . Only provably equal or narrower changes skip review.
Honest policy compiler	If Privy cannot enforce a term on the chosen execution method, Kanon refuses to compile. It never approximates a limit.
Two planes, strict order	Privy enforces money movement. ENSv2 publishes identity and approved state, written only after Privy confirms.

Owner authority never enters the agent runtime

Browser + Vercel proxy

- React 19 + Vite workspace
- No secrets in the browser
- Proxy sends a restricted demo credential, never the company token
- Route allowlist, body cap

Kanon API (Render, Node 22)

- Installation state machine + human decisions
- Permission engine and Privy policy compiler
- ENS writer (company role) with readback
- Demo role, terms ceiling, rate limits, session lease
- Neon PostgreSQL

Isolated runner (Render)

- Holds only the agent's delegated key
- Re-reads installation before every run
- Refuses stale, revoked or mismatched authority

Privy

- Wallet owned by company key quorum
- Additional signer + override policy
- Rolling-value aggregation on `eth_signTransaction`

ENSv2 on Sepolia

- Company namespace → agents registry → agent name
- Permissioned Resolver, Enhanced Access Control
- Agent owner cannot rewrite protected records

Stack

- TypeScript monorepo (pnpm)
- viem, pg, tsx
- Vitest, ESLint, Prettier, GitHub Actions

From a working proof to a public prototype anyone can safely repeat

- **Reliable connection.** Timed retries, a visible wake-up state, faster start-up and keep-warm pings.
- **Safe public demo.** Company token removed from the proxy. Restricted demo role, terms ceiling, rate limits.
- **Repeatable flow.** Session lease; idle sessions expire through real revocation. No manual ENS resets.
- **Execution in the UI.** Allowed, forbidden and post-revoke attempts with on-chain evidence.
- **Judge path.** Twelve-step rail, live ENS record panel, reject-update path.
- **Verification.** `pnpm smoke:live` replays the full flow against production without credentials.

All Kanon code was written September 12–26, 2026, inside the 3rd-Web-Hack submission period. It was also built for ETHOnline 2026. Git history is unchanged.

Let small teams use financial agents without trusting them with everything

Who

Crypto-native startups, DAOs, and teams paying contributors or vendors onchain.

What changes

"This agent, this release, this much, to this recipient", enforced by the wallet and visible on ENS.

Where it applies

Payroll, treasury rebalancing, recurring payments or a company's own agent. Kanon is agent-agnostic.

Human attention goes to authority changes, not to every routine payment.

Next steps

- Quorum approval for large authority changes.
- ERC-20 stablecoin terms once the policy path is verified end to end.
- A dedicated wallet and ENS namespace per organization instead of a shared demo fixture.
- Provider-failure rollback integration tests for updates.
- Independent security review before any mainnet or production use.

Current limits: Sepolia testnet only, not audited, not production custody, no external users.

Kanon

An agent receives exactly the authority a human approved,
and a software update cannot silently widen it.

Try it: kanon-agents.vercel.app

Code: github.com/CryptoZephyr/Kanon (MIT)